

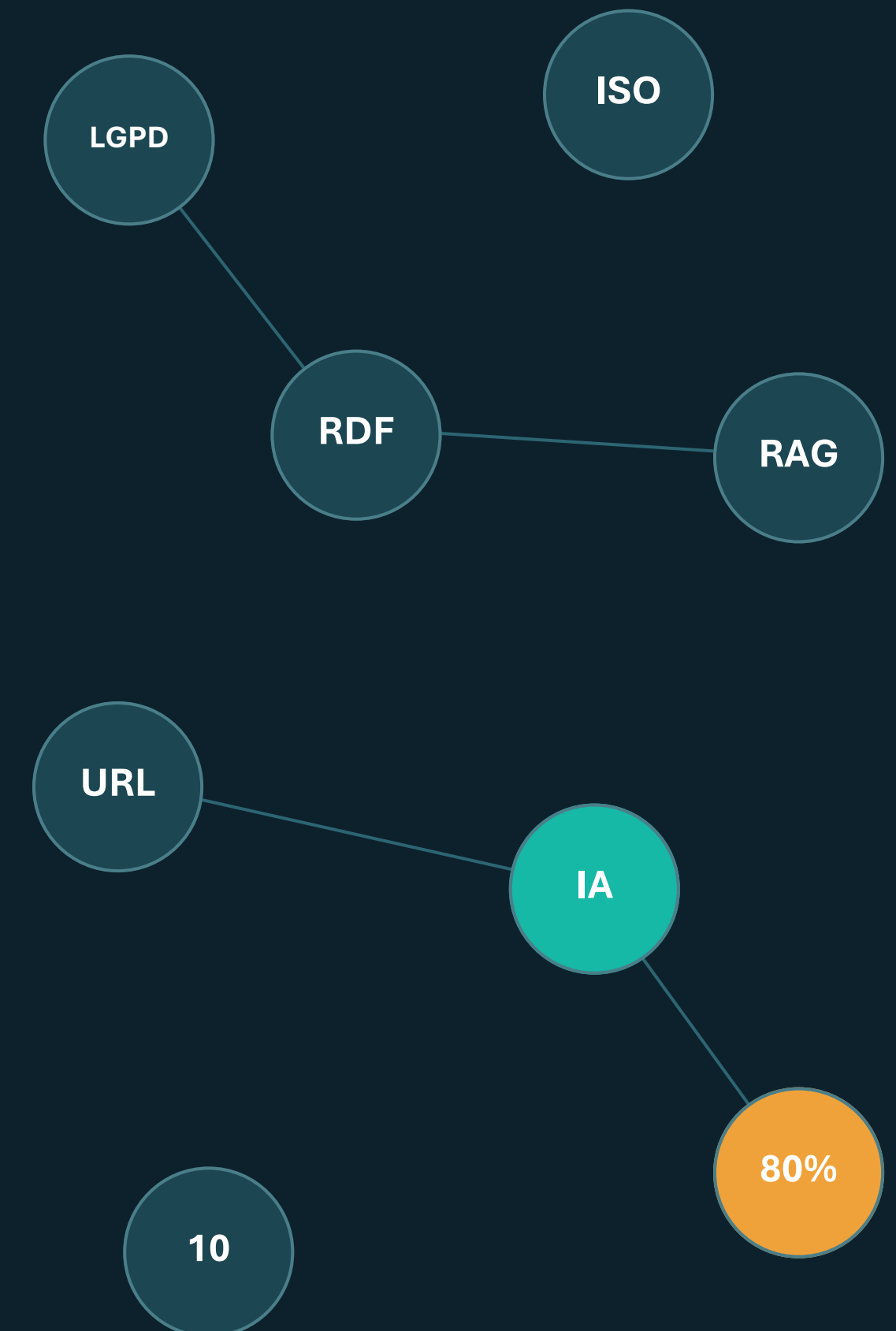
LGPD Standards and Laws Analyzer for Websites

Auditoria automatizada de compliance usando GraphRAG, Web Semântica e rastreabilidade por evidências.

Flávio Mesquita • Yuri De Lima • John Victor

Universidade Federal da Paraíba — Ciência da Computação

A ideia central: transformar textos legais extensos em uma análise objetiva, explicável e acionável.



Por que esse problema importa?

A conformidade não está em um único documento — ela está espalhada entre leis, normas, políticas e práticas técnicas.

01

Volume e complexidade

LGPD, ISO 27001, ISO 27002, ISO 31000 e TPRM usam linguagens e estruturas diferentes.

02

Auditoria manual

Ler páginas, localizar evidências e cruzar requisitos demanda tempo e conhecimento especializado.

03

Baixa rastreabilidade

Uma resposta genérica de IA não basta: é preciso indicar onde está a evidência e qual norma sustenta o diagnóstico.

Problema de pesquisa: como automatizar a auditoria sem perder explicabilidade e fundamento normativo?

Objetivo e proposta de valor

OBJETIVO PRINCIPAL

páginas públicas de um site e comparar seu conteúdo com requisitos legais e

Saída: índice de conformidade, evidências por URL e linha, fundamentação normativa e recomendações.

1

Entrada simples

URLs de termos, privacidade, cookies ou suporte.

2

Análise fundamentada

GraphRAG recupera os requisitos relacionados no grafo.

3

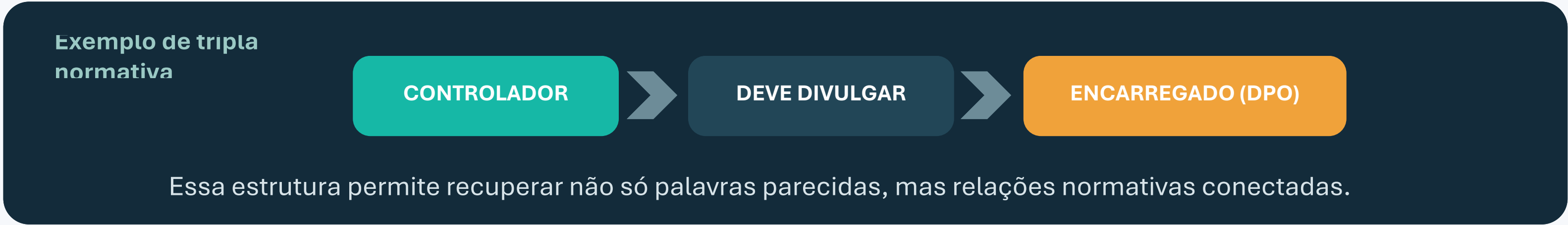
Resultado acionável

O sistema mostra o que está correto e o que precisa ser corrigido.

Do texto jurídico → para uma decisão técnica verificável.

Base de conhecimento: leis viram relações

O sistema reúne cinco fontes normativas e organiza conceitos em triplas: sujeito → relação → objeto.



Fonte: README do projeto — base LGPD, ISO 27001/27002, ISO 31000 e TPRM; 51 triplas no estudo de caso.

Por que GraphRAG — e não apenas busca por palavras?

RAG TRADICIONAL

Recupera trechos com termos semanticamente próximos.

Pode encontrar a palavra “incidente”, mas não necessariamente conectar prazo, obrigação, responsável e norma.

chunk A

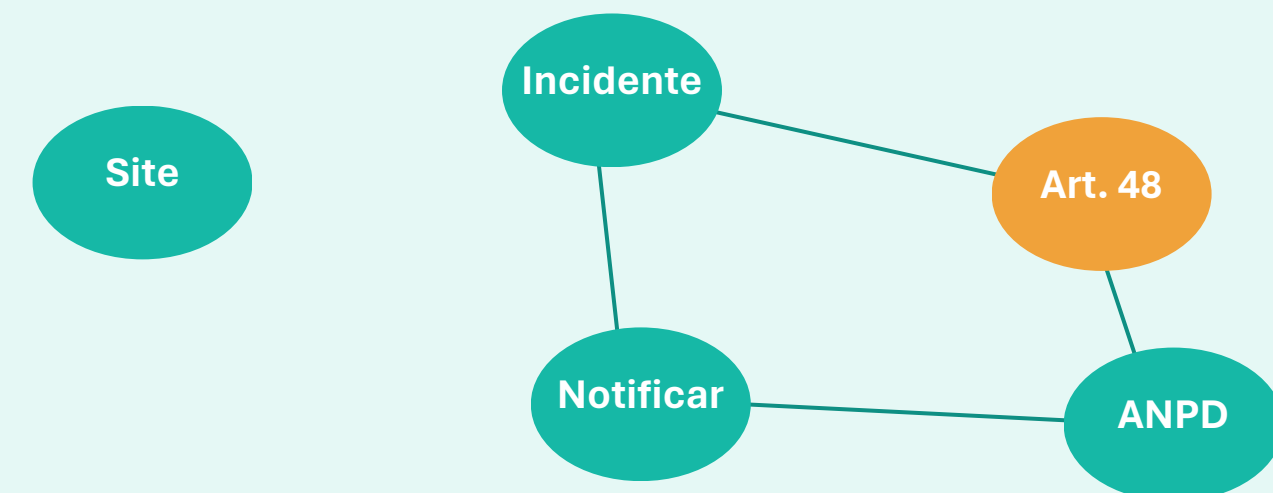
chunk B

chunk C

GRAPHRAG

Recupera um subgrafo com entidades, obrigações e dependências relacionadas.

A consulta ativa conexões relevantes e entrega contexto normativo mais estruturado ao motor de IA.



Mais contexto → melhor justificativa → maior auditabilidade

Arquitetura de ponta a ponta

O pipeline foi organizado para manter rastreabilidade desde a entrada da URL até o relatório final.



Rastreabilidade preservada: URL + número da linha + requisito + norma de referência

Componentes do repositório: util_scraper.py, compliance_graphrag.py, knowledge_graph.ttl, app_ui.py e geradores de relatório.

Interface: da configuração ao diagnóstico

Configurações da análise

Provedor de IA

Ollama Local

URLs para auditoria

vizinhub.com.br/privacy
vizinhub.com.br/terms

Executar auditoria

51 triplas carregadas

GraphRAG Compliance & Auditoria Suite

80%
Conformidade

8
Conformes

2
Não conformes

0
Atenções

Requisitos auditados

AUD-001Controlador e CNPJCONFORME

AUD-004Encarregado (DPO)NÃO CONFORME

AUD-008Resposta a incidentesNÃO CONFORME

A interface Streamlit inclui dashboard, filtros, chat em linguagem natural, gerenciador de triplas e exportação.

Estudo de caso: auditoria do Vizinho Hub

2 páginas públicas
Política de Privacidade e Termos de Uso

10 requisitos
Tópicos críticos de compliance

51 triplas
Relações na base de conhecimento

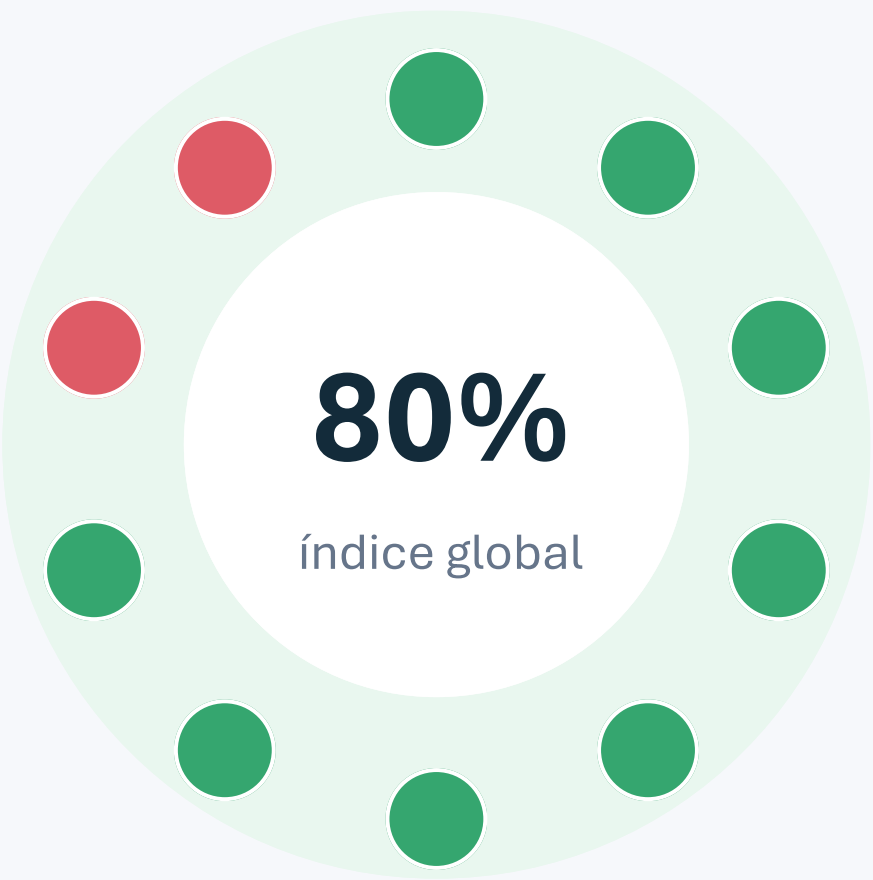
2× paralelização
Tópicos processados simultaneamente

O que foi verificado?

- Controlador e identificação
- Bases legais e finalidade
- Direitos do titular
- Encarregado (DPO)
- Segurança e criptografia
- Terceiros e transferência
- Cookies e opt-out
- Resposta a incidentes
- Retenção e descarte
- Dados sensíveis e crianças

Execução registrada em 27/07/2026; motor heurístico com Gemini 2.0 Flash no relatório fornecido.

Resultados: 80% de conformidade



Matriz dos 10 requisitos

AUD-001 OK	AUD-002 OK	AUD-003 OK	AUD-004 FALHA	AUD-005 OK
AUD-006 OK	AUD-007 OK	AUD-008 FALHA	AUD-009 OK	AUD-010 OK

O painel mostra rapidamente onde concentrar o esforço de correção.

Fonte: relatorio_auditoria.json e relatorio_auditoria.md do projeto.

As duas lacunas encontradas — e como corrigir

AUD-004 • NÃO CONFORME

Encarregado pelo tratamento de dados (DPO)

Problema

Ausência de indicação pública e clara do encarregado e do canal de contato.

Ação recomendada

Publicar nome ou identificação do encarregado, responsabilidades e canal de atendimento.

AUD-008 • NÃO CONFORME

Notificação e resposta a incidentes de segurança

Problema

A política não descreve claramente protocolo, comunicação e responsabilidades em caso de incidente.

Ação recomendada

Definir fluxo de resposta, canal de comunicação, responsáveis e compromisso de notificação aplicável.

Referências usadas pelo sistema: LGPD Art. 41 para DPO e LGPD Art. 48 / ISO 27002 A.16 para incidentes.

Diferenciais técnicos e limitações

Diferenciais

- 1 **Rastreabilidade** URL e linha da evidência
- 2 **Web Semântica** RDF/OWL e consultas SPARQL
- 3 **Execução flexível** Ollama local, Gemini ou regras
- 4 **Base extensível** Geração e deduplicação de triplas
- 5 **Experiência completa** Dashboard, chat e exportação

Limitações e próximos passos

-  **Não substitui parecer jurídico**
A saída deve apoiar revisão humana especializada.
-  **Qualidade depende da fonte**
Políticas incompletas ou ambíguas afetam a análise.
-  **Grafo ainda pequeno**
Ampliar triplas, casos e normas setoriais.
-  **Avaliação experimental**
Comparar resultados com especialistas e métricas formais.

O projeto é uma ferramenta de apoio à auditoria, não uma certificação automática de conformidade.

CONCLUSÃO

De documentos extensos a decisões verificáveis.

O projeto demonstra que GraphRAG pode apoiar auditorias de LGPD e segurança com mais contexto, rastreabilidade e foco em ação.

ENTRADA

URLs públicas

PROCESSO

Grafo + IA

SAÍDA

Evidência + ação



Pergunta para encerrar

**Sua organização
sabe exatamente
onde suas políticas
deixam de cumprir a
LGPD?**

Obrigado!